

AWS IAM - Deep-Dive Notes

What is AWS IAM?

IAM (Identity and Access Management) is a global AWS service that helps you securely manage access to AWS services and resources. You use IAM to control who is authenticated (signed in) and authorized (has permissions) to use resources. IAM is a global service, not region-specific. It controls access to global services like IAM, S3, CloudFront, etc.

IAM Root User

When you create an AWS account, you're given a Root User with full, unrestricted access to all AWS services and resources. Use it only for initial setup and secure it with MFA. Avoid using it for daily tasks.

IAM Identities: Users, Groups, Roles

IAM Users: Represents a person or application, assigned username, password, access keys.

IAM Groups: Collection of users, used to apply policies to multiple users.

IAM Roles: Identity with permissions that can be assumed by another user/service for temporary access.

IAM Policies: Controlling Permissions

Policies are JSON documents defining permissions.

Identity-Based Policies:

- Attached to users, groups, or roles.
- Types: AWS Managed, Customer Managed, Inline.

Resource-Based Policies:

- Attached directly to AWS resources like S3 or Lambda.

IAM Permission Boundaries

Set maximum permissions a user or role can have. Useful for limiting access regardless of attached policies.

Session Policies

AWS IAM - Deep-Dive Notes

Temporary permissions passed during session creation. Helps restrict what can be done in a session.

Access Control List (ACL)

Older mechanism for controlling access to S3 objects. Grants simple read/write permissions to AWS accounts.

AWS Organizations - Service Control Policies (SCP)

Used in multi-account environments to control permissions at the organization or account level. SCPs define permission guardrails.

IAM Role Use Cases

- EC2 to S3: Role lets EC2 access S3 buckets.
- Lambda to DynamoDB: Lambda uses role to access DynamoDB.
- SAML Federation: Users log in with corporate credentials.
- Cross-Account Access: Assume roles across AWS accounts.

Summary of Key Concepts

Root User: Full access, use sparingly

IAM User: Individual with credentials

IAM Group: Logical grouping

IAM Role: Temporary identity

Policy: Defines permissions

Permission Boundary: Max permissions

SCP: Org-level controls

Session Policy: Temporary permissions

ACL: Legacy S3 access control

Federation: External identity login

Best Practices

Use roles for apps, not long-term credentials

Enable MFA

AWS IAM - Deep-Dive Notes

Grant least privilege

Use groups

Review access regularly

Enforce guardrails with SCPs

Rotate credentials regularly